

Tema 41. Ciberdelincuencia y agentes de la Amenaza

Ciberdelincuencia y agentes de la Amenaza: Botnet; Business E-mail Compromise; Cartas nigerianas; Cryptojacking; Denegación de servicio; Ingeniería social; Inyección SQL; Malware; Pharming; Phishing; Spear phishing; Ransomware; Skimming; Spoofing; Spyware, Troyano; XSS; Zero-day. Cibercriminales. Crimen as Service. Hacktivistas. Insider threat. APTs. Cyber Kill Chain.

FUENTES

Apuntes del tema 41 (apuntes propios, NO texto oficial)

Redactados para esta plataforma porque el programa pide materia que no recoge ninguna norma. Pendientes de revisión.

Alcance en este tema: Todo el tema.

Documento generado el 2026-09-03 para Atenea Policial a partir de los textos consolidados del BOE. Contiene únicamente los preceptos que el programa oficial asigna a este tema.

Ciberdelincuencia y agentes de la amenaza

GLOSARIO DE TÉCNICAS Y AMENAZAS

BOTNET. Red de dispositivos infectados («bots» o «zombis») controlados de forma remota y unificada por un atacante a través de un servidor de mando y control. Se emplea para ataques de denegación de servicio distribuidos, envío masivo de correo basura, minado de criptomonedas o distribución de malware. El propietario del equipo infectado normalmente no lo advierte.

BUSINESS EMAIL COMPROMISE (BEC), también llamado fraude del CEO. Estafa dirigida a empresas en la que el atacante suplanta a un directivo o a un proveedor —tras comprometer o imitar su correo— y ordena una transferencia urgente y confidencial. No requiere malware: se apoya en la jerarquía, la urgencia y la confianza.

CARTAS NIGERIANAS o estafa 419. Fraude de pago anticipado: se promete una gran suma (una herencia, un fondo bloqueado, una lotería) a cambio de adelantar cantidades menores en concepto de gastos o impuestos. El nombre procede del artículo del código penal nigeriano que la castiga.

CRYPTOJACKING. Uso no autorizado de la capacidad de cómputo de un dispositivo ajeno para minar criptomonedas. Se manifiesta como ralentización, sobrecalentamiento y aumento del consumo. Puede ejecutarse desde el propio navegador con solo visitar una web.

DENEGACIÓN DE SERVICIO (DoS) y DENEGACIÓN DE SERVICIO DISTRIBUIDA (DDoS). Ataque que satura un servicio con peticiones hasta dejarlo inoperativo para los usuarios legítimos. En la variante distribuida el ataque procede simultáneamente de multitud de equipos, normalmente una botnet, lo que dificulta el bloqueo por origen.

INGENIERÍA SOCIAL. Conjunto de técnicas de manipulación psicológica para inducir a una persona a revelar información o realizar una acción que compromete la seguridad. Es el vector transversal: explota la confianza, la urgencia, la autoridad, el miedo y la reciprocidad. Se considera el eslabón más débil y el más rentable para el atacante, porque no requiere vulnerar sistemas.

INYECCIÓN SQL. Ataque a aplicaciones web que consiste en insertar sentencias de base de datos en un campo de entrada mal validado, de modo que el servidor las ejecuta. Permite leer, modificar o borrar información de la base de datos, e incluso eludir la autenticación.

MALWARE. Término genérico para todo programa diseñado para dañar o para actuar sin conocimiento del usuario. Comprende virus (necesitan un archivo anfitrión), gusanos (se propagan solos por la red), troyanos, spyware, ransomware, adware, rootkits y keyloggers.

PHARMING. Redirección del usuario a una web fraudulenta idéntica a la legítima manipulando la resolución de nombres: alterando el archivo hosts del equipo o envenenando la caché de un servidor DNS. Se distingue del phishing en que la víctima teclea correctamente la dirección y aun así acaba en el sitio falso.

PHISHING. Suplantación de una entidad de confianza, normalmente por correo electrónico, para obtener credenciales o datos bancarios mediante un enlace o un archivo adjunto. Variantes por canal: SMISHING (por SMS) y VISHING (por llamada de voz).

SPEAR PHISHING. Phishing DIRIGIDO a una persona u organización concreta, elaborado con información previa sobre la víctima, lo que lo hace mucho más creíble. Cuando el objetivo es un alto directivo se denomina

whaling.

RANSOMWARE. Programa que cifra los archivos de la víctima —o bloquea el dispositivo— y exige un rescate, habitualmente en criptomoneda, a cambio de la clave. En su modalidad de doble extorsión, el atacante además exfiltra la información y amenaza con publicarla. La recomendación institucional es no pagar: no garantiza la recuperación y financia la actividad.

SKIMMING. Copia de la banda magnética de una tarjeta mediante un dispositivo instalado en un cajero o terminal, junto con la captura del PIN por microcámara o teclado superpuesto, para fabricar duplicados. La variante digital, sobre pasarelas de pago en comercios electrónicos, se conoce como web skimming.

SPOOFING. Suplantación de identidad técnica falsificando un dato de origen. Modalidades: IP spoofing, email spoofing (remitente falso), DNS spoofing, ARP spoofing (en red local, para interceptar tráfico), caller ID spoofing (número de teléfono falso) y GPS spoofing.

SPYWARE. Programa que recopila información del usuario y la envía a un tercero sin consentimiento: hábitos de navegación, credenciales, ubicación. Los **KEYLOGGERS**, que registran las pulsaciones del teclado, son una modalidad; los stalkerware, comercializados para vigilar a la pareja, otra.

TROYANO. Programa que se presenta como legítimo o útil y oculta una funcionalidad maliciosa. A diferencia del virus y del gusano, no se autorreplica: depende de que el usuario lo ejecute. Los troyanos de acceso remoto (**RAT**) dan al atacante control del equipo; los bancarios interceptan operaciones financieras.

XSS (Cross-Site Scripting). Inyección de código de script en una página web legítima que se ejecuta en el navegador de otros usuarios. Permite robar cookies de sesión, suplantar al usuario o redirigirlo. Se distingue del **SQL injection** en que el objetivo no es la base de datos del servidor, sino el navegador de la víctima.

ZERO-DAY o día cero. Vulnerabilidad desconocida para el fabricante y para la que, por tanto, no existe parche. El exploit de día cero es el código que la aprovecha. Su valor en el mercado clandestino es muy alto precisamente porque no hay defensa específica disponible.

AGENTES DE LA AMENAZA

CIBERCRIMINALES. Motivación económica. Actúan de forma organizada, con reparto de funciones y en muchos casos con estructura empresarial: desarrolladores, distribuidores, blanqueadores y mulas de dinero.

CRIME AS A SERVICE (CaaS). Modelo de negocio del cibercrimen: las capacidades se alquilan como servicio, de modo que quien ataca no necesita conocimientos técnicos. Comprende ransomware como servicio, alquiler de botnets, kits de phishing, servicios de denegación de servicio por encargo y venta de accesos por parte de los llamados intermediarios de acceso inicial.

HACKTIVISTAS. Motivación ideológica o política. Buscan visibilidad y denuncia mediante desfiguración de sitios web, filtraciones o ataques de denegación de servicio. Anonymous es el ejemplo más conocido.

INSIDER THREAT o amenaza interna. Procede de quien tiene acceso legítimo: empleado, ex empleado, contratista o proveedor. Puede ser **MALICIOSA** (por resentimiento, lucro o captación externa) o **NO INTENCIONADA** (por negligencia o desconocimiento). Es especialmente peligrosa porque elude los controles perimetrales: el atacante ya está dentro.

APT (Advanced Persistent Threat, amenaza persistente avanzada). Actor con capacidades y recursos elevados, habitualmente vinculado a un Estado, que se infiltra en una organización y permanece en ella el mayor tiempo posible sin ser detectado. Sus tres notas son las de su nombre: **AVANZADA** en técnica, **PERSISTENTE** en el tiempo y con carácter de **AMENAZA** dirigida. Su objetivo suele ser el espionaje o el sabotaje, no el lucro inmediato.

Otros actores: script kiddies, que emplean herramientas ajenas sin comprenderlas; ciberterroristas; y actores estatales en operaciones de desinformación.

LA CYBER KILL CHAIN

Modelo desarrollado por Lockheed Martin que descompone un ciberataque en **SIETE FASES**. Su utilidad defensiva es que basta con romper una fase para frustrar el ataque completo:

RECONOCIMIENTO. Recogida de información sobre el objetivo, a menudo mediante fuentes abiertas.

PREPARACIÓN o armamentización (weaponization). Se construye el artefacto: se combina un exploit con una carga útil.

DISTRIBUCIÓN (delivery). Se hace llegar al objetivo: correo, memoria USB, web comprometida.

EXPLOTACIÓN. Se aprovecha la vulnerabilidad y se ejecuta el código.

INSTALACIÓN. Se implanta una puerta trasera que garantiza la persistencia.

MANDO Y CONTROL (C2). El equipo comprometido establece comunicación con el atacante.

ACCIONES SOBRE EL OBJETIVO. Exfiltración de datos, cifrado, destrucción o movimiento lateral hacia otros sistemas.

Modelos complementarios que conviene conocer por su nombre: la matriz MITRE ATT&CK, que cataloga tácticas y técnicas observadas en ataques reales, y el modelo del Diamante, que analiza cada intrusión mediante cuatro vértices: adversario, capacidad, infraestructura y víctima.

